

Mapeo detallado GQM + PRAGMATIC a requisitos normativos

Versión 1.0 – 2026

1. Introducción

Esta tabla enlaza los objetivos y métricas GQM descritos en el marco integrativo con los principales requisitos normativos y de referencia: NIS2/NIS360 (ENISA), ENS, ISO 27001, NIST CSF/RMF, DORA y estrategias nacionales y europeas.[web:9][web:12][web:13][web:5][web:3]

2. Tabla de mapeo

Objetivo GQM	Métrica (ID)	Descripción métrica	NIS2 / NIS360	ENS / ISO 27001	NIST CSF / RMF	DORA / otros	Estrategias ES / UE
GOB-1	GOB-1.1.a	% org. críticas con estrategia de ciberseguridad aprobada últimos 3 años	Art. 21 NIS2 (gestión de riesgos); NIS360 gov. [web:9] [web:12]	ENS org.2; ISO 27001 A.5 (políticas)	CSF Govern (GV); RMF Prepare	DORA Art. 5 (estrategia TIC)	Estrategia Nacional Ciberseguridad; España Digital 2025[web:3][web:5]
GOB-1	GOB-1.2.a	% org. con CISO con acceso regular al consejo	Art. 20 NIS2 (responsabilidad dirección) [web:9]	ENS org.1; ISO 27001 gobierno de seguridad	CSF Govern roles	DORA gobernanza TIC	Estrategias sectoriales CN; UE Cybersecurity Strategy[web:12]
GOB-1	GOB-1.3.a	% org. que reportan ciberseguridad al máximo órgano de gobierno ≥ semestral	NIS2 supervisión; NIS360 métricas	ENS org.1; ISO 27001 9.1 (seguimiento)	CSF Govern reporting	DORA reporting interno	Informes de la Década Digital (Country Report) [web:2]
RIESGO-1	RIESGO-1.1.a	% org. con servicios críticos mapeados a activos tecnológicos	NIS2 identificación servicios esenciales; NIS360 criticidad[web:9] [web:12]	ENS categorización; ISO 27005 análisis activos	CSF Identify (ID.AM)	DORA servicios críticos financieros	Plan Nacional de Ciberseguridad; Digital Spain 2025[web:3][web:5]

RIESGO-1	RIESGO-1.2.a	Nº de sectores en zona de riesgo (criticidad alta / madurez baja)	NIS360 sector maturity and risk zone[web:9][web:12]	ENS enfoque sectorial	CSF Identify / Govern	Supervisión macroprudencial	Evaluaciones europeas de resiliencia sectorial[web:12]
RIESGO-1	RIESGO-1.3.a	% org. que realizan análisis de riesgos al menos anualmente	Art. 21 NIS2; NIS360 risk management	ISO 27005; ISO 27001 6.1; ENS op.1	NIST RMF (Categorize, Assess)	DORA gestión de riesgos TIC	Estrategia Nacional Ciberseguridad[web:3]
CUMP-1	CUMP-1.1.a	% org. con cumplimiento “alto/sistémico” con marcos aplicables	NIS2 medidas; ENS; ISO; DORA	ENS; ISO 27001 implementación control	CSF Protect / Detect / Respond	DORA cumplimiento operativo	Evaluaciones regulatorias sectoriales
CUMP-1	CUMP-1.2.a	% org. con auditorías de ciberseguridad en últimos 24 meses	NIS2 supervisión; NIS360 maturity assessment[web:9][web:12]	ISO 27001 auditorías internas y externas	RMF Monitor	DORA revisión periódica	ENS auditoría; revisiones CNMC, BdE, etc.
CUMP-1	CUMP-1.3.a	% org. con inventario de controles mapeado a requisitos normativos	NIS2 medidas técnicas y organizativas	ENS e ISO 27001 A.5–A.18; catálogo CCN	CSF Protect (PR)	DORA control framework	Programas nacionales de cumplimiento ENS[web:5]
CAP-1	CAP-1.1.a	% org. con MFA extendido a todos los usuarios internos	NIS2 seguridad de redes y sistemas	ENS control de acceso; ISO 27001 A.9	CSF Protect (PR.AC)	DORA autenticación reforzada	Guías CCN e INCIBE sobre MFA

CAP-1	CAP-1.2.a	% org. que usan ZTNA/SA SE como modelo predominante de acceso remoto	NIS360 modern architectures	ENS op.2; buenas prácticas ISO 27001	CSF Protect / Identify	DORA resiliencia tecnológica	Iniciativas de Zero Trust en sector público
CAP-1	CAP-1.3.a	% org. con SOC 24x7 con EDR/XDR	NIS2 detección incidentes	ENS detección; ISO 27001 A.12–A.16	CSF Detect / Respond	DORA monitorización continua	Plan Nacional Ciberseguridad (capacidad SOC) [web:3]
RES-1	RES-1.1.a	% org. con BCP/DRP que contempla ciberataques y pruebas periódicas	NIS2 resiliencia y continuidad	ISO 22301; ENS continuidad de operación	CSF Recover (RC)	DORA continuidad operativa	Estrategia Nacional de Seguridad ; planes sectoriales
INV-1	INV-1.1	% presupuesto TIC dedicado a ciberseguridad	NIS2 proporcionalidad de medidas	Gestión de recursos ISO 27001	CSF Govern (GV.RR)	DORA asignación de recursos	Informes de inversión digital España Digital 2025[web:5][web:1]
INV-1	INV-1.2	Evolución del presupuesto de ciberseguridad en 3 años	NIS2 mejora continua	ISO 27001 mejora continua	RMF Monitor	DORA planificación plurianual	Estadísticas nacionales de inversión TIC

INV-1	INV-1.3	Existencia de modelos de ROI basados en pérdida esperada	Recomendaciones de buenas prácticas	ISO 31000; ISO 27005	RMF riesgo cuantitativo	Supervisión financiera	Orientación de ENISA/NIST sobre métricas de riesgo[web:9][web:13]
--------------	---------	--	-------------------------------------	----------------------	-------------------------	------------------------	---

Nota: este mapeo es una guía de alineamiento conceptual y no sustituye el análisis jurídico específico para cada sector o entidad.